

Universidad Politécnica de San Luis Potosí

ACTIVIDAD 04

Una página demasiado convincente

Presentado por:

Christian Alfredo Morales Meza — 184937

Asignatura: CNO IV Seguridad Informática

Profesor: Servando López Contreras

Fecha de entrega: 31/08/2026

Índice de contenido

Índice de contenido	2
Objetivo de la actividad.....	3
Objetivos específicos.....	3
Descripción del escenario.....	3
¿Qué es un Credential Harvester y cuál es su función dentro de una campaña de phishing?	4
Configuración del laboratorio	5
Restricciones aplicadas durante la práctica (cumplimiento obligatorio)	6
Evidencias y descripción del funcionamiento	10
Inicio de SET y acceso al módulo Credential Harvester.....	10
Configuración del módulo y puesta en marcha del servidor	12
Simulación del acceso de la «víctima»	14
Revisión de la evidencia capturada	17
Explicación del flujo de captura de información.....	17
Indicadores técnicos y visuales de una página fraudulenta.....	19
Controles de seguridad propuestos.....	19
Conclusión.....	20
Referencias	21

Objetivo de la actividad

El objetivo de esta actividad es implementar y analizar, dentro de un entorno de laboratorio controlado, una simulación de ingeniería social apoyada en Social-Engineer Toolkit (SET). A través de una página web ficticia construida específicamente para esta práctica, se busca comprender de forma práctica cómo funciona una técnica de captura de información de tipo phishing, y reconocer los elementos técnicos y visuales que permiten identificar un intento de este tipo antes de caer en él.

Objetivos específicos

- Configurar un escenario básico de ingeniería social utilizando Social-Engineer Toolkit (SET) sobre una red interna y aislada.
- Implementar una página web ficticia de inicio de sesión mediante el módulo Credential Harvester, respetando los límites éticos y técnicos del laboratorio.
- Analizar el proceso mediante el cual la información introducida en un formulario web es transmitida por el navegador y registrada por el servidor del atacante.
- Identificar los indicadores técnicos y visuales que permiten reconocer una página potencialmente fraudulenta.
- Proponer controles de seguridad orientados a prevenir o reducir el impacto de ataques de phishing en un entorno organizacional real.

Descripción del escenario

Para darle contexto a la práctica, planteé el siguiente escenario ficticio: el área de seguridad informática de una organización recibe reportes de varios empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales. El mensaje contiene un enlace que dirige a un portal aparentemente institucional, el cual incluye un logotipo, campos de usuario y contraseña, y una advertencia que indica: «Su sesión ha expirado. Inicie sesión nuevamente para continuar».

A primera vista, la página no presenta elementos que llamen la atención de un usuario común; sin embargo, el portal no pertenece a la organización real, sino que es un montaje de laboratorio que construí con fines exclusivamente académicos, alojado de forma local.

¿Qué es un Credential Harvester y cuál es su función dentro de una campaña de phishing?

Un Credential Harvester («recolector de credenciales») es un módulo de Social-Engineer Toolkit que automatiza la creación de una página web falsa con formularios de inicio de sesión. Su función es capturar y almacenar la información que una víctima introduce en dichos campos —usuario y contraseña— en el momento en que la envía, sin que exista de por medio ningún proceso real de autenticación.

Dentro de una campaña de phishing, el Credential Harvester representa la etapa de «captura»: después de que la víctima es engañada mediante un pretexto —un correo, mensaje o enlace que simula una notificación legítima, como una sesión expirada—, es dirigida a esta página falsa. Al ingresar sus credenciales, estas quedan registradas en el equipo del atacante y, habitualmente, la víctima es redirigida a la página legítima o a un mensaje de error, con el fin de no despertar sospechas.

Para esta práctica, diseñé el formulario HTML que utilicé como página ficticia dentro del Credential Harvester. A continuación, se muestra el código completo de ese formulario.

```
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>Portal Interno - Sistema de Autenticación (Laboratorio)</title>
  <style>
    body { font-family: Arial, sans-serif; background:#eef1f5; display:flex;
      justify-content:center; align-items:center; height:100vh; margin:0; }
    .box { background:#fff; padding:40px; border-radius:8px;
      box-shadow:0 2px 10px rgba(0,0,0,.15); width:320px; text-align:center; }
    .box h2 { color:#2c3e50; margin-bottom:5px; }
    .box p.sub { color:#7f8c8d; font-size:13px; margin-top:0; }
    .warning { background:#fdecea; color:#c0392b; padding:10px;
      border-radius:4px; font-size:13px; margin-bottom:20px; }
    input { width:90%; padding:10px; margin:8px 0; border:1px solid #ccc; border-radius:4px; }
    button { width:96%; padding:10px; background:#2c3e50; color:#fff;
      border:none; border-radius:4px; cursor:pointer; }
  </style>
```

```

</head>
<body>
  <div class="box">
    <h2>SIST-LAB Corp</h2>
    <p class="sub">Portal ficticio de autenticación (uso académico)</p>
    <div class="warning">Su sesión ha expirado. Inicie sesión nuevamente para continuar.</div>
    <form action="post.php" method="POST">
      <input type="text" name="username" placeholder="Usuario">
      <input type="password" name="password" placeholder="Contraseña">
      <button type="submit">Iniciar sesión</button>
    </form>
  </div>
</body>
</html>

```

Este HTML fue el único archivo (index.html) que utilicé como base para el módulo Custom Import de SET, tal como se describe en la sección de configuración del laboratorio.

Configuración del laboratorio

Para llevar a cabo esta práctica configuré un entorno de laboratorio aislado, compuesto por dos máquinas virtuales dentro de VirtualBox: una con Kali Linux, que utilicé como equipo atacante, y otra con Windows 7, que utilicé como equipo víctima. La tabla siguiente resume el entorno y las herramientas empleadas.

Elemento	Detalle
Sistema operativo atacante	Kali Linux (máquina virtual)
Herramienta principal	Social-Engineer Toolkit (SET) — módulo Credential Harvester Attack Method
Modo de red	Red interna (Internal Network) entre dos máquinas virtuales, sin salida a Internet
Página utilizada	Página ficticia diseñada para el laboratorio (Custom Import), sin relación con servicios reales
IP del servidor local (Kali / atacante)	192.168.50.10 (asignada manualmente en eth0, ya que la Red Interna no cuenta con DHCP)
Máquina "víctima"	Windows 7 (máquina virtual), IP 192.168.50.20, misma red interna
Fecha de ejecución	30 de agosto de 2026

Nota sobre la configuración de red: al utilizar el modo Red Interna (Internal Network) del hipervisor, ninguna de las dos máquinas virtuales recibe una dirección IP de forma automática, ya que este modo no incluye un servidor DHCP. Por esa razón tuve que asignar manualmente una dirección IP a cada una de las máquinas, dentro del mismo segmento de red, para que pudieran comunicarse entre sí sin salir hacia Internet.

Restricciones aplicadas durante la práctica

Antes de iniciar la configuración técnica, se definieron un conjunto de restricciones con el fin de mantener la práctica dentro de un marco estrictamente académico y controlado:

- No utilicé páginas pertenecientes a servicios reales.
- No cloné portales de instituciones o empresas; en su lugar, usé la opción Custom Import con una página propia.
- No empleé credenciales personales, únicamente datos de prueba inventados.
- No solicité datos a personas ajenas al laboratorio.
- El servidor nunca fue publicado hacia Internet; se mantuvo en una red interna de tipo host-only.
- No utilicé dominios externos ni técnicas de suplantación DNS.
- No instalé payloads ni ejecuté código malicioso de ningún tipo.

El primer paso técnico consistió en configurar la red de ambas máquinas virtuales, la de Linux y la de Windows, en modo Red Interna, con lo que cumplí la restricción de no publicar el servidor hacia Internet. Utilicé el nombre de red por defecto «intnet» en las dos máquinas, ya que ambos adaptadores deben compartir el mismo nombre de red interna para poder verse entre sí.

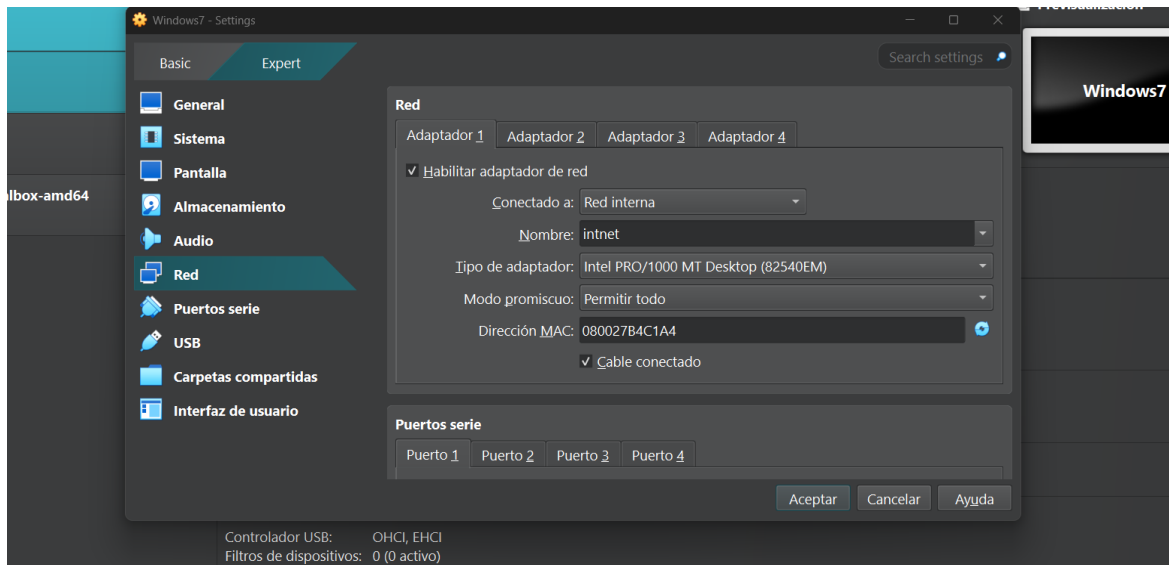


Figura 1. Configuración de la red interna «intnet» en VirtualBox para la máquina virtual Windows 7.

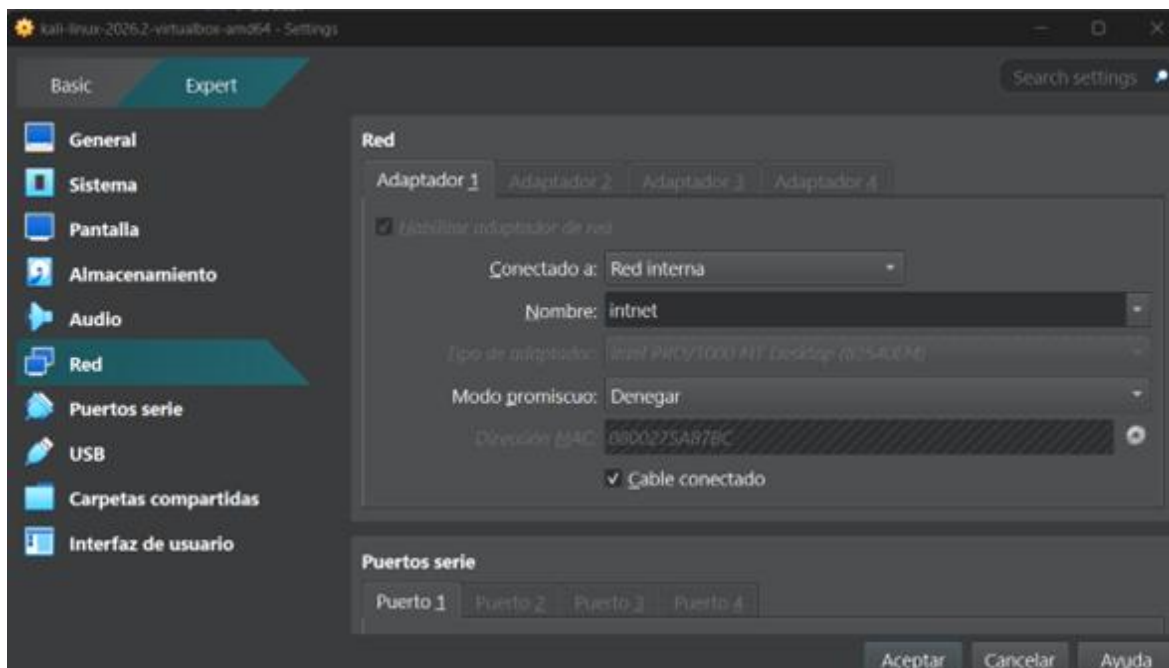


Figura 2. Configuración de la misma red interna «intnet» en VirtualBox para la máquina virtual Kali Linux.

Con la red interna ya configurada en el hipervisor, tuve que asignar manualmente una dirección IP a la interfaz de red de Kali Linux mediante el comando `ip addr add`, y configurar después una IP estática dentro del mismo segmento en la máquina virtual con Windows 7, de manera que ambos equipos pudieran comunicarse entre sí.

En Kali, asigné la IP manualmente con los siguientes comandos:

- `sudo ip addr add 192.168.50.10/24 dev eth0`
- `sudo ip link set eth0 up`

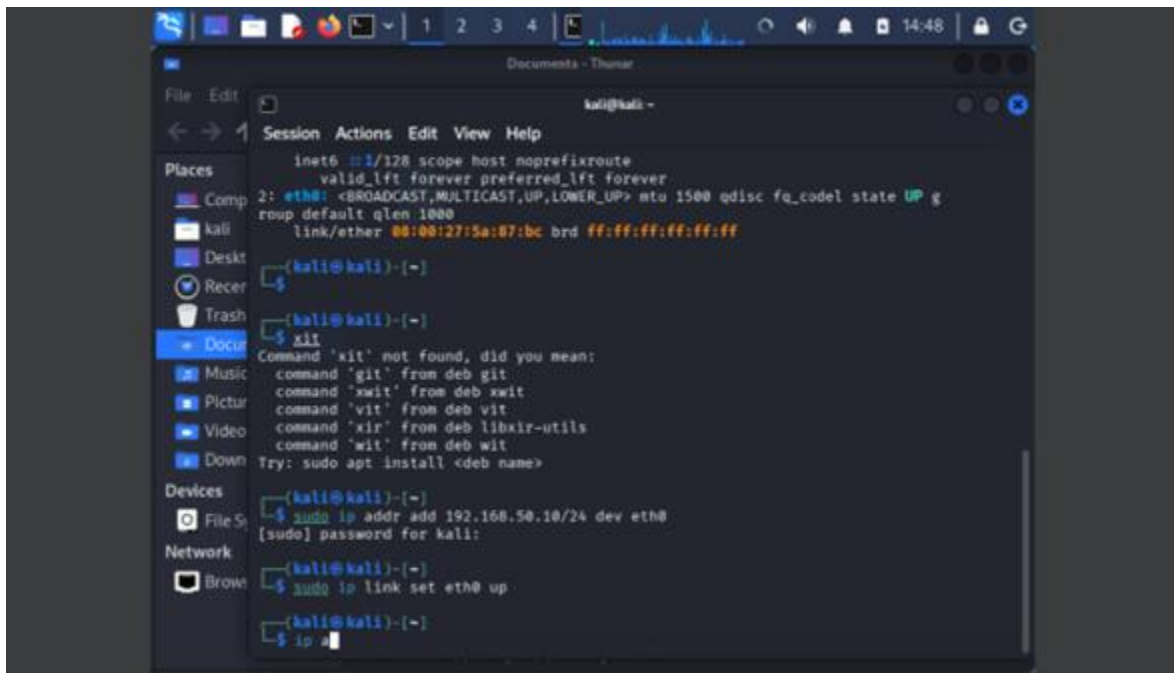


Figura 3. Asignación manual de la dirección IP 192.168.50.10/24 sobre la interfaz eth0 en Kali Linux.

Después verifiqué que la IP hubiera quedado correctamente asignada con el comando:

- `ip a`

Con esto pude confirmar que la interfaz eth0 mostraba correctamente inet 192.168.50.10/24, lo que significaba que la configuración de red del equipo atacante había quedado lista.

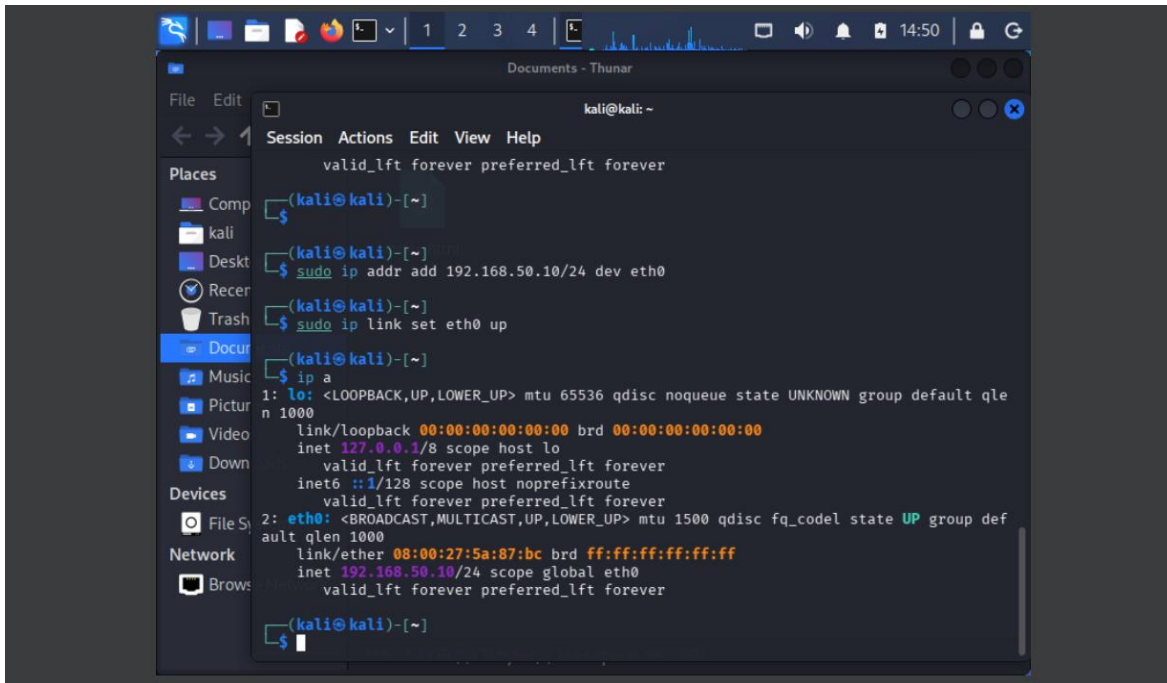


Figura 4. Verificación de la dirección IP asignada en Kali Linux mediante el comando `ip a`.

Del lado de Windows 7, asigné la IP correspondiente dentro del mismo segmento 192.168.50.x siguiendo la ruta Panel de control → Redes e Internet → Centro de redes y recursos compartidos → clic en el adaptador de red → Propiedades.

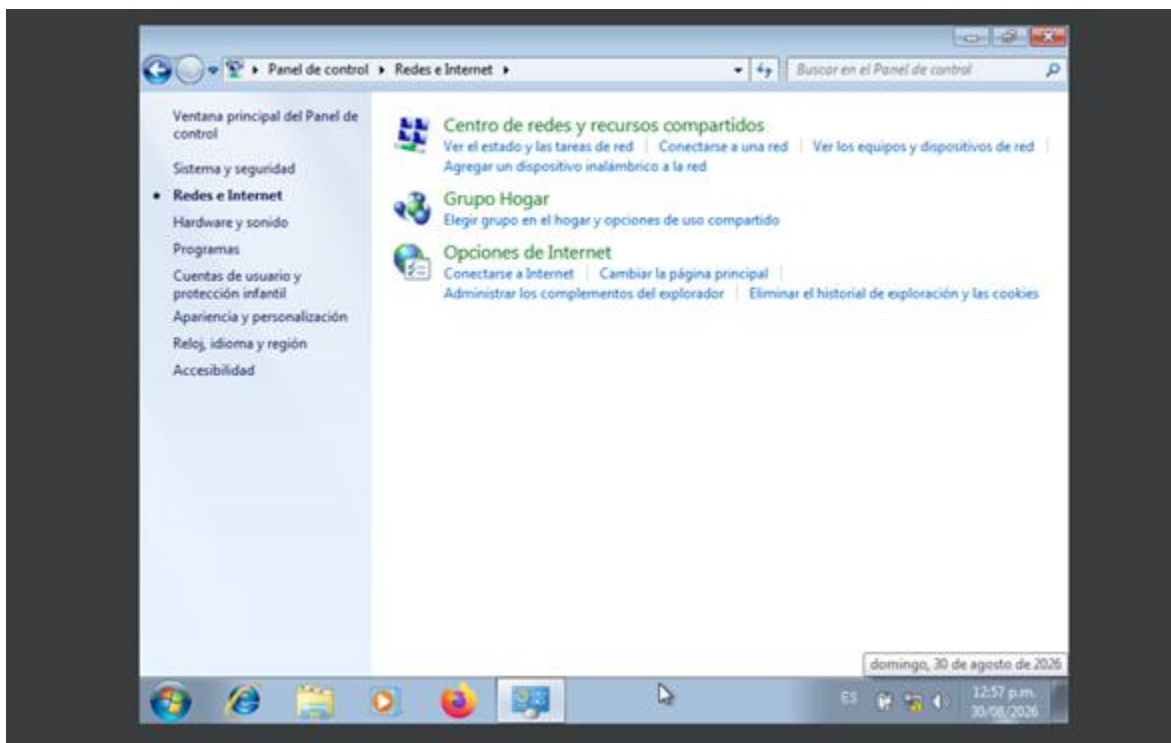


Figura 5. Acceso al Centro de redes y recursos compartidos en Windows 7 para editar las propiedades del adaptador.

Dentro de las propiedades, seleccioné «Protocolo de Internet versión 4 (TCP/IPv4)» y elegí la opción «Usar la siguiente dirección IP», donde configuré los siguientes valores: dirección IP 192.168.50.20, máscara de subred 255.255.255.0 y puerta de enlace vacía, ya que esta máquina no necesitaba salir a ninguna otra red.

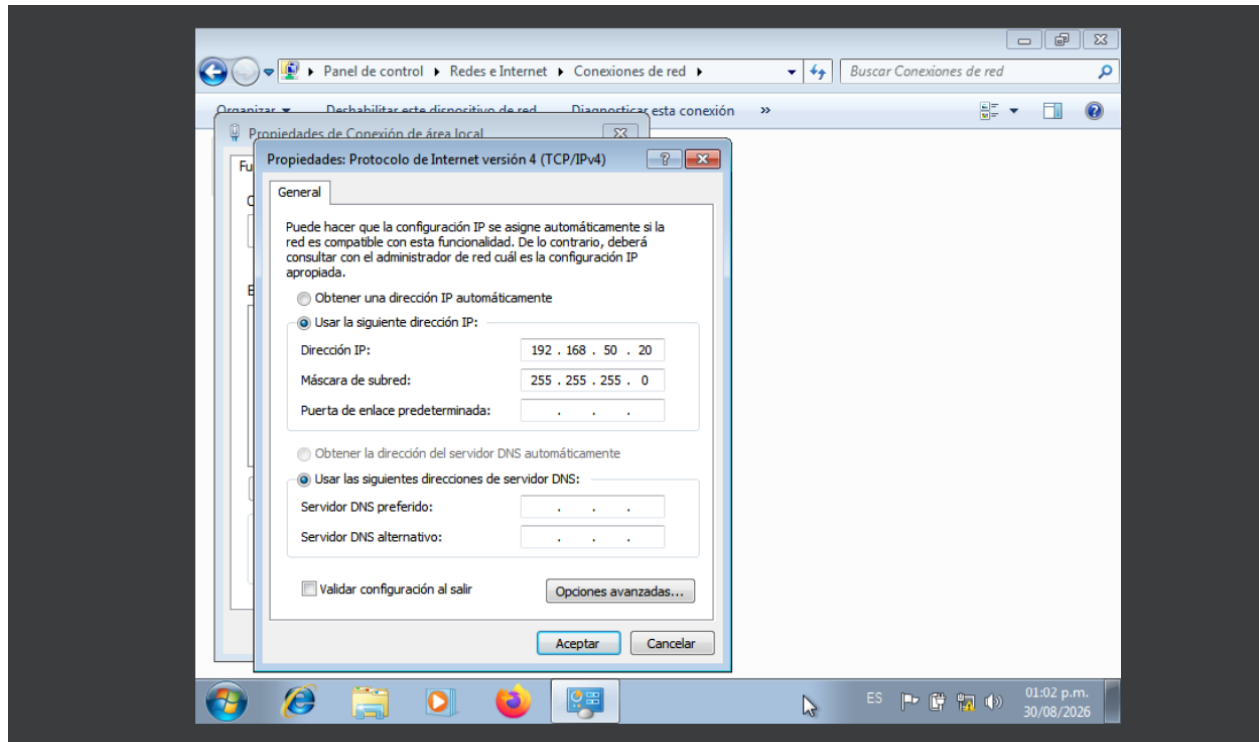


Figura 6. Configuración de la dirección IP estática 192.168.50.20 en el adaptador de red de Windows 7.

Evidencias y descripción del funcionamiento

Inicio de SET y acceso al módulo Credential Harvester

Con la red ya funcionando entre ambas máquinas, abrí una terminal en Kali Linux y ejecuté Social-Engineer Toolkit con el siguiente comando:

- `sudo setoolkit`

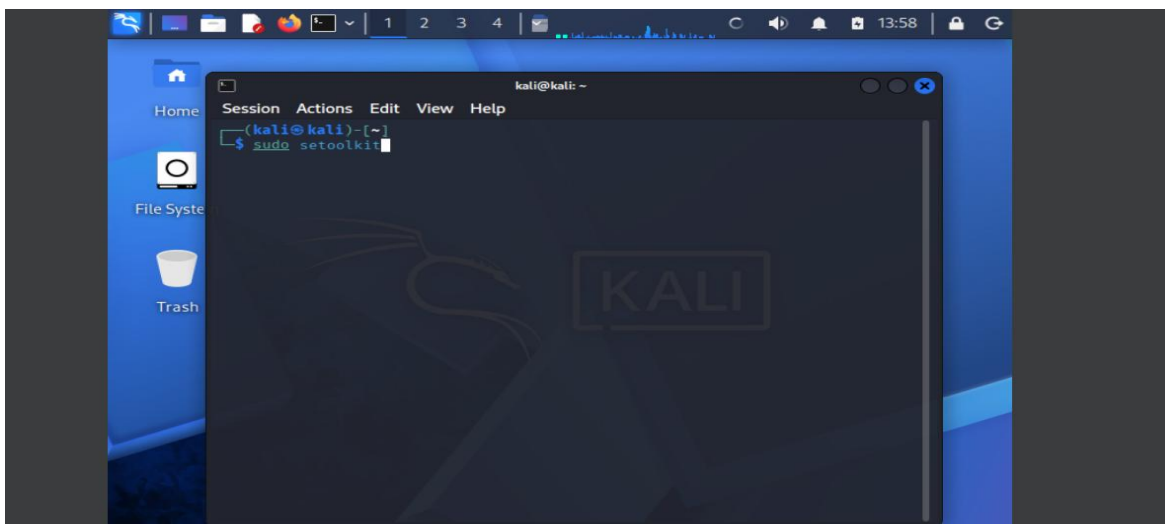


Figura 7. Inicio de Social-Engineer Toolkit desde una terminal de Kali Linux mediante el comando setoolkit.

Acepté los términos de uso de la herramienta y, a continuación, se desplegó el menú principal de SET, desde donde comencé a navegar hacia el módulo que necesitaba.

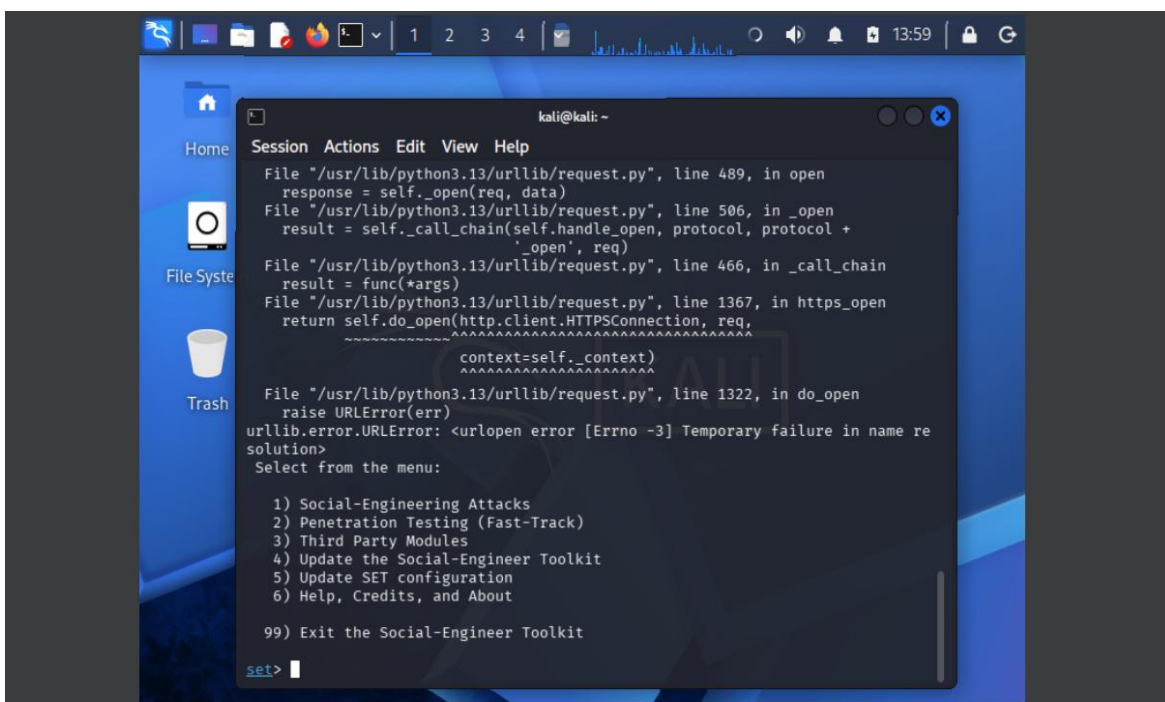


Figura 8. Menú principal de Social-Engineer Toolkit tras aceptar los términos de uso.

Dentro del menú principal seguí la siguiente ruta de navegación:

- 1) Social-Engineering Attacks

- 2) Website Attack Vectors
- 3) Credential Harvester Attack Method

Al llegar a este punto, SET me presentó tres opciones para definir el origen de la página que quería utilizar: 1) Web Templates, que ofrece plantillas predefinidas por la propia herramienta; 2) Site Cloner, que clona una URL real ya existente; y 3) Custom Import, que permite importar un sitio propio. Elegí esta última opción porque era la única que cumplía la restricción de trabajar únicamente con una página diseñada por mí para el laboratorio, sin clonar ningún portal real.

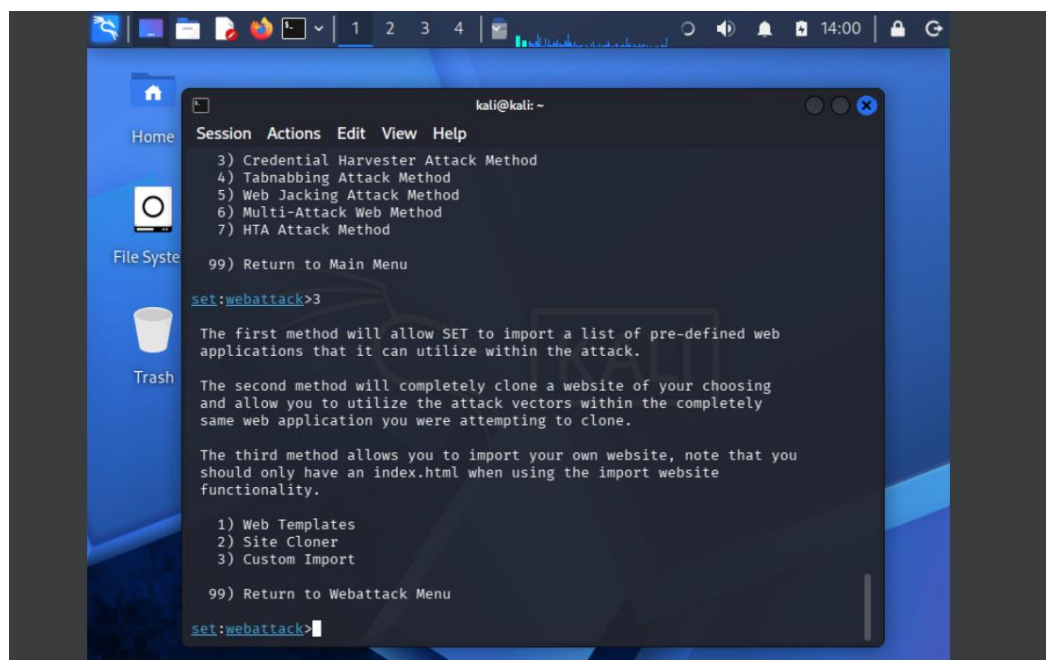


Figura 9. Submenú Website Attack Vectors: descripción de las tres opciones disponibles y selección de Custom Import.

Configuración del módulo y puesta en marcha del servidor

Una vez dentro de Custom Import, SET me pidió dos datos: la dirección IP a la que debían reenviarse los formularios (POST back) y la ruta donde tenía guardada mi página. En el primer campo indiqué la IP de mi propia máquina Kali, 192.168.50.10 —nunca una IP externa—, y a la página ficticia le asigné además una URL simbólica, `http://sistlab.local`, únicamente como referencia dentro del laboratorio.

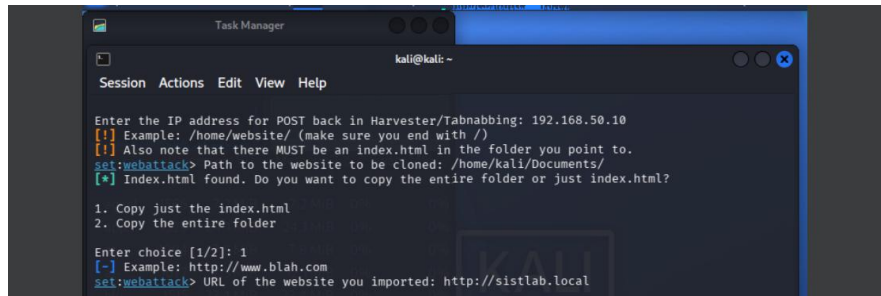


Figura 10. Configuración del módulo Credential Harvester: IP de retorno (192.168.50.10), ruta del sitio importado y URL asignada al portal ficticio.

Antes de continuar, verifiqué en el gestor de archivos de Kali que el archivo index.html con el formulario que había programado sí se encontrara en la ruta que le indiqué a SET, /home/kali/Documents/.

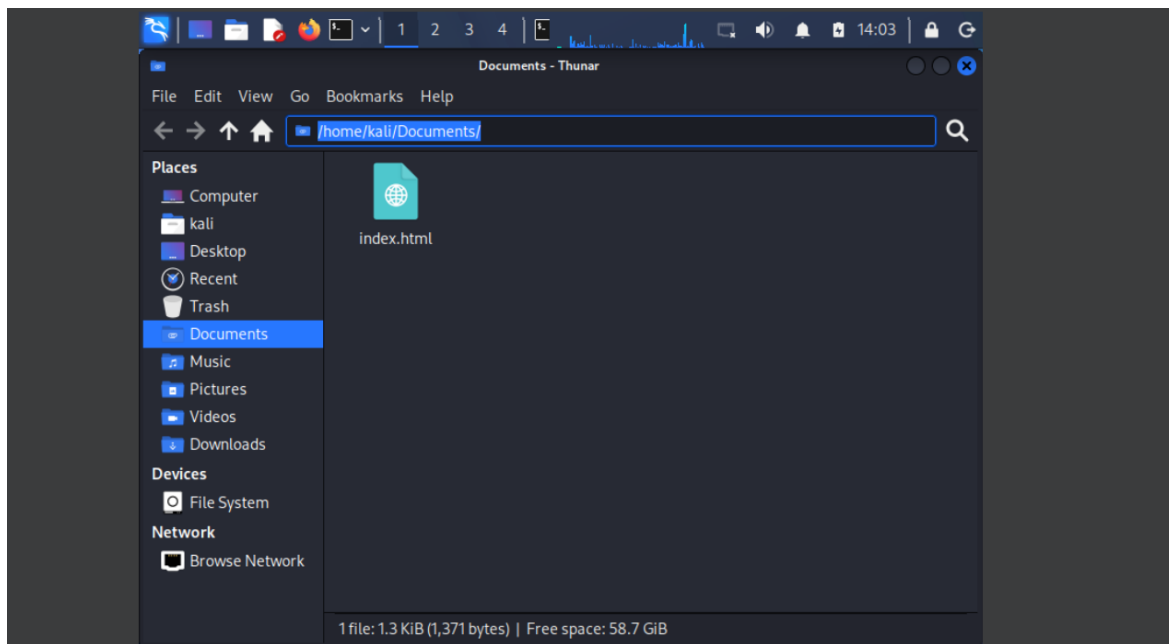
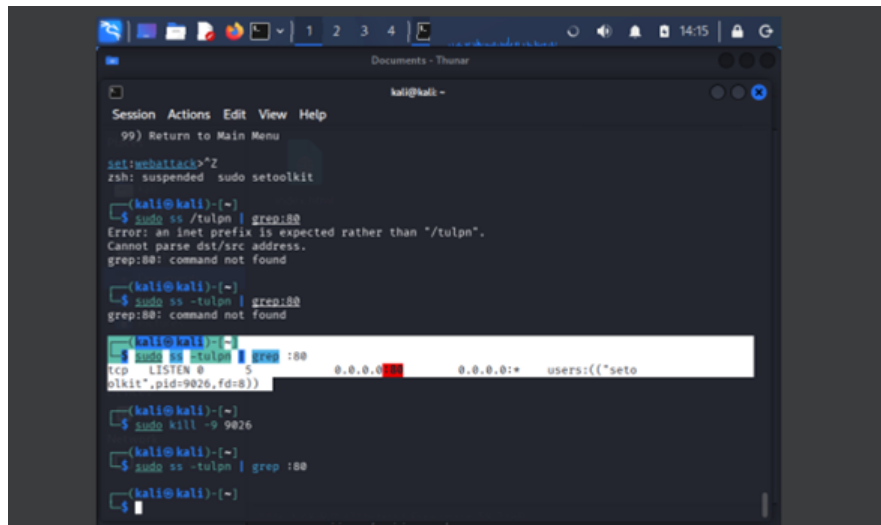


Figura 11. Verificación del archivo index.html dentro de la carpeta /home/kali/Documents/ antes de importarlo en SET.

Con la ruta y la IP configuradas, SET copió el archivo hacia su propio directorio de trabajo, montó un servidor web local sobre Apache en el puerto 80 y quedó a la espera de recibir las credenciales que se enviaran desde el formulario.

Durante la primera ejecución me encontré con un inconveniente: el puerto 80 ya estaba siendo utilizado por un proceso anterior, por lo que SET no pudo levantar el servidor. Para resolverlo,

identifiqué el proceso que estaba ocupando el puerto con el comando `ss -tulpn | grep :80`, localicé su PID —en este caso, 9026— y lo terminé con `sudo kill -9 9026`.



```
Session Actions Edit View Help
99) Return to Main Menu

set:webhacker>*Z
zsh: suspended sudo setoolkit

(kali@kali)-[~]
$ sudo ss -tulpn | grep:80
Error: an inet prefix is expected rather than "/tulpn".
Cannot parse dst/src address.
grep:80: command not found

(kali@kali)-[~]
$ sudo ss -tulpn | grep:80
grep:80: command not found

(kali@kali)-[~]
$ sudo ss -tulpn | grep :80
tcp LISTEN 0      5            0.0.0.0:80      0.0.0.0:*      users:((("setoolkit",pid=9026,fd=8))

(kali@kali)-[~]
$ sudo kill -9 9026

(kali@kali)-[~]
$ sudo ss -tulpn | grep :80

(kali@kali)-[~]
$
```

Figura 12. Identificación del proceso que ocupaba el puerto 80 (PID 9026) y finalización del proceso con `sudo kill -9`.

Una vez liberado el puerto, volví a iniciar el módulo Credential Harvester y repetí la configuración: la ruta hacia mi `index.html`, la confirmación de que el archivo había sido encontrado y la URL asignada al portal ficticio, esta vez sin ningún conflicto de puerto.

Simulación del acceso de la «víctima»

Con el servidor ya escuchando en el puerto 80, pasé a la máquina virtual con Windows 7 —que hacía el papel de equipo víctima— y abrí el navegador para visitar la dirección `http://192.168.50.10`, es decir, la IP de mi máquina Kali.

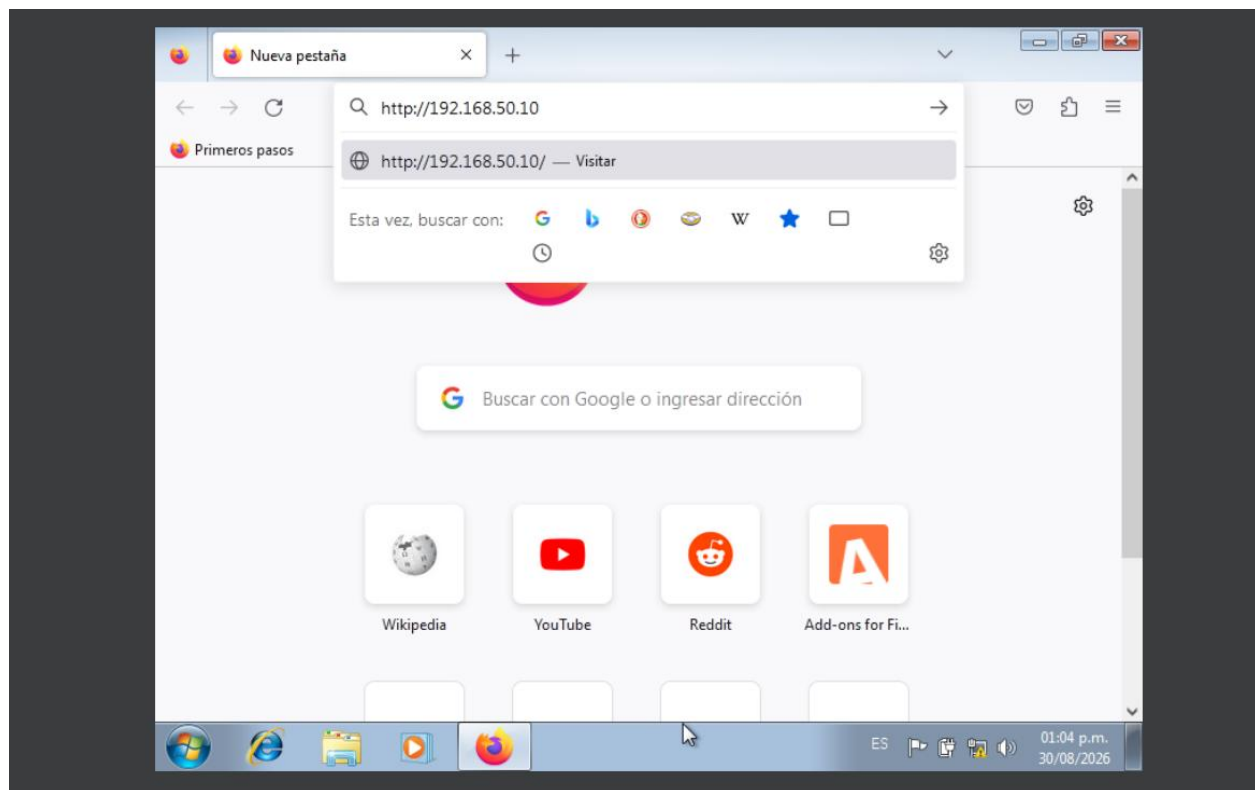


Figura 14. Acceso desde el navegador de la máquina «víctima» (Windows 7) a la dirección <http://192.168.50.10>.

En el navegador apareció mi página ficticia, con el mensaje de sesión expirada tal como la había diseñado. Para simular el comportamiento de un usuario engañado, escribí credenciales completamente inventadas —usuario prueba01 y contraseña Lab2026#— y presioné el botón «Iniciar sesión».

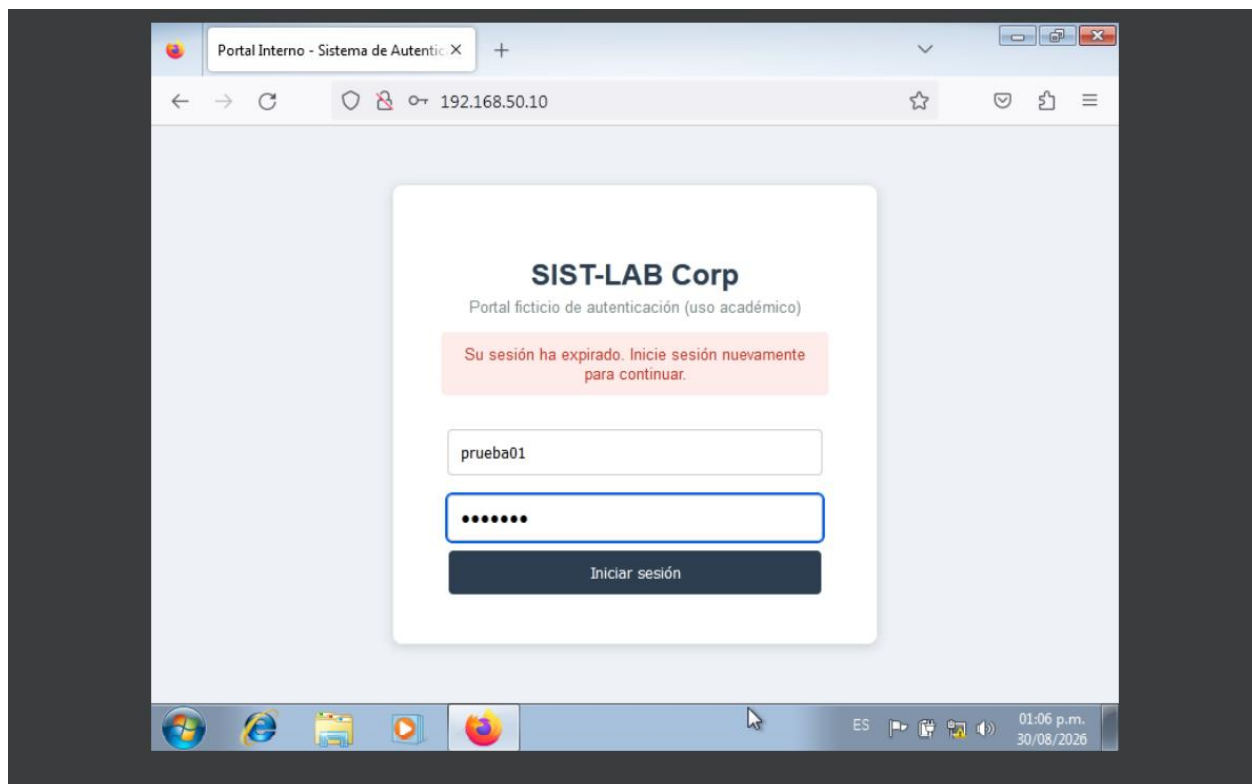
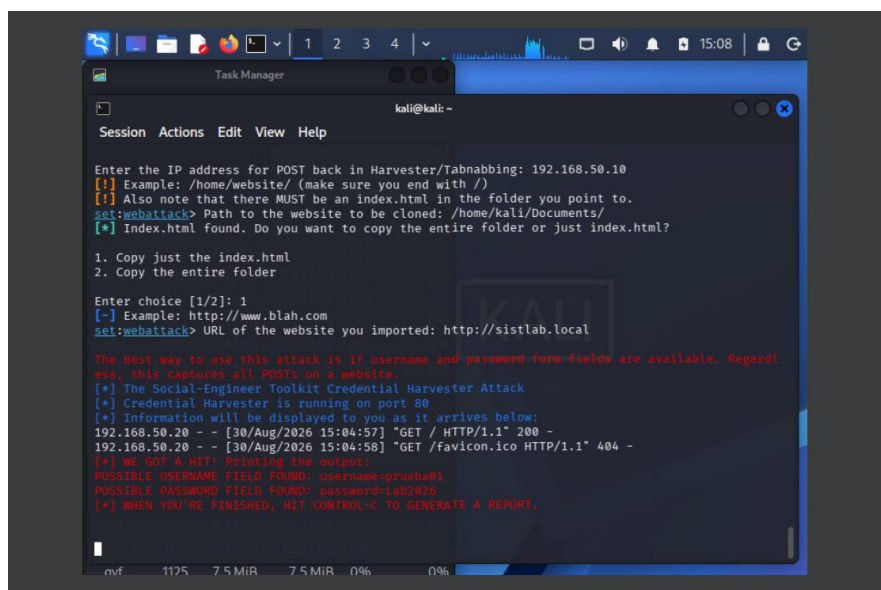


Figura 15. Página ficticia de autenticación «SIST-LAB Corp» mostrando las credenciales de prueba ingresadas antes de enviarlas.

En cuanto envié el formulario, regresé a la terminal donde tenía corriendo SET y pude ver, en tiempo real, cómo la herramienta reportaba la petición HTTP recibida y extraía de ella los valores de los campos username y password que acababa de escribir en el navegador.



*Figura 16. Registro en tiempo real de la petición HTTP recibida y de las credenciales capturadas:
username=prueba01, password=Lab2026#.*

Revisión de la evidencia capturada

Para finalizar la captura, regresé a la terminal donde corría SET y presioné Ctrl + C para detener el módulo Credential Harvester. Al hacerlo, la herramienta generó un archivo de registro con la sesión, el cual pude consultar con el comando cat y la ruta que la propia SET indicó al terminar el proceso.

```
sudo cat /usr/share/set/src/logs/harvester.log
```



Figura 17. Revisión del archivo harvester.log generado por SET, donde quedaron registradas las credenciales de prueba capturadas.

Explicación del flujo de captura de información

A partir de lo que observé durante la práctica, puedo resumir el flujo técnico del ataque simulado en los siguientes pasos:

- SET, a través del módulo Credential Harvester, levanta un servidor web local (Apache) que aloja la página ficticia que importé.
- El navegador de la «víctima» accede a la IP del servidor y visualiza el formulario de inicio de sesión tal como lo diseñé.

- Al completar los campos de usuario y contraseña y presionar el botón de ingreso, el formulario envía una petición HTTP de tipo POST hacia el servidor.
- El script del Credential Harvester intercepta los parámetros enviados en esa petición (username, password) antes de que exista cualquier proceso real de autenticación.
- Los datos capturados se registran en un archivo de texto en el servidor y, al mismo tiempo, se muestran en tiempo real en la terminal donde corre SET.
- Finalmente, la víctima suele ser redirigida a otra página —por ejemplo, la legítima o un mensaje de error— con el fin de reducir la sospecha de que algo salió mal.

En mi caso particular, como la URL ficticia `http://sistlab.local` no correspondía a ningún dominio real ni estaba registrada en un servidor DNS, al intentar acceder a ella el navegador mostró un mensaje de error de tipo «servidor no encontrado». En un escenario real, un atacante sustituiría este paso por una redirección funcional hacia el sitio legítimo, precisamente para no levantar sospechas en la víctima.

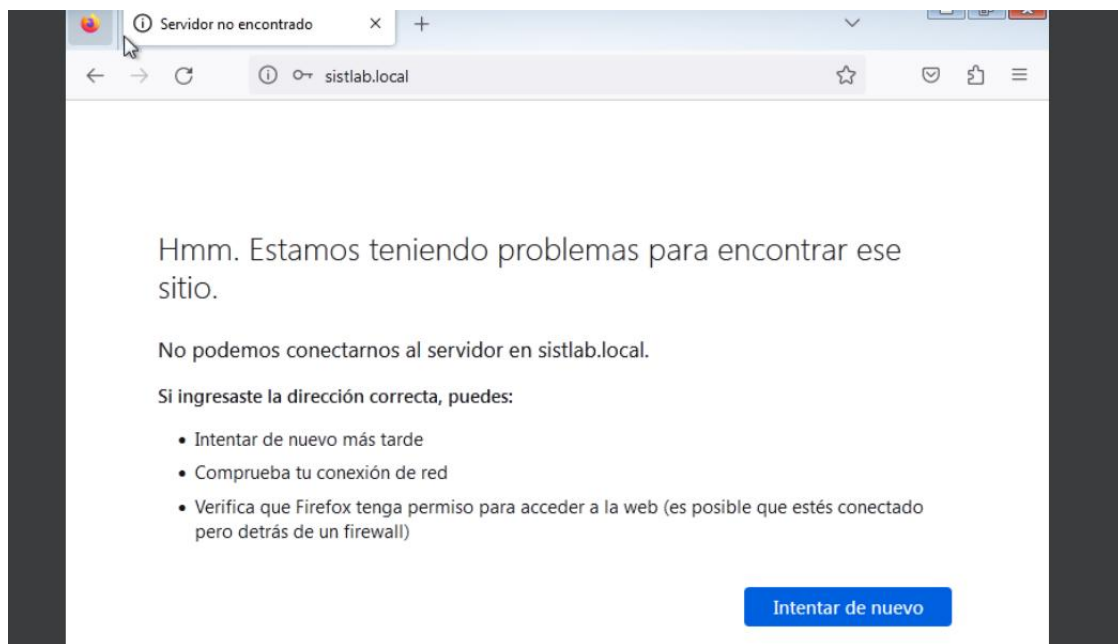


Figura 18. Mensaje de error mostrado tras el envío del formulario, al no existir una resolución DNS real para el dominio ficticio `sistlab.local`.

Indicadores técnicos y visuales de una página fraudulenta

A partir de lo observado durante la práctica, identifique los siguientes indicadores como señales típicas de una página fraudulenta:

- URL o dominio que no corresponde al dominio oficial de la organización, o uso de una dirección IP en lugar de un nombre de dominio.
- Ausencia de un certificado SSL válido o del candado de seguridad en la barra del navegador.
- Mensajes de urgencia genéricos, como «su sesión ha expirado» o «actualice sus credenciales de inmediato», diseñados para presionar una reacción rápida.
- Diseño visual ligeramente distinto al oficial: logotipos de baja calidad, tipografías o colores inconsistentes con la identidad real de la organización.
- Un formulario que no realiza validaciones reales ni redirige a un panel funcional después del envío.
- Un enlace recibido por un canal no oficial, como un correo no corporativo o un mensaje inesperado.

Controles de seguridad propuestos

Con base en lo analizado durante la práctica, propongo los siguientes controles para prevenir o reducir el impacto de ataques de phishing en una organización real:

- **Capacitación y concientización periódica del personal:** para que sepan identificar correos y enlaces sospechosos antes de interactuar con ellos.
- **Autenticación multifactor (MFA):** de modo que una sola credencial capturada no sea suficiente para acceder a los sistemas de la organización.
- **Filtrado de correo electrónico y soluciones anti-phishing a nivel de gateway:** que detecten y bloqueen mensajes sospechosos antes de que lleguen al usuario final.
- **Registros SPF, DKIM y DMARC:** configurados correctamente en el dominio de correo para reducir la suplantación de identidad del remitente.

- **Listas de reputación de URLs:** y bloqueo de dominios recién registrados o con comportamiento sospechoso.
- **Simulacros periódicos de phishing controlados:** similares al de esta práctica, para medir y reforzar la respuesta del personal ante intentos reales.
- **Monitoreo de accesos anómalos:** con alertas ante inicios de sesión desde ubicaciones o dispositivos inusuales.
- **Políticas claras de reporte inmediato:** ante la sospecha de un correo o página fraudulenta, con un canal simple para que cualquier empleado pueda notificarlo.

Conclusión

Esta práctica me permitió comprobar, de forma muy concreta, qué tan sencillo puede resultar montar un escenario de phishing funcional cuando se cuenta con las herramientas adecuadas.

También me quedó claro que, desde el punto de vista del atacante, la etapa de «captura» que realiza el Credential Harvester es solo el último eslabón de una cadena que comienza mucho antes, con el pretexto que convence a la víctima de hacer clic en el enlace. Por eso considero que los controles más efectivos no son únicamente los técnicos —como MFA, filtrado de correo o registros SPF/DKIM/DMARC—, sino también los que fortalecen el criterio del usuario final, como la capacitación periódica y los simulacros controlados.

En conjunto, el laboratorio cumplió su propósito: pude observar de primera mano el funcionamiento interno de un ataque de phishing basado en captura de credenciales, sin poner en riesgo información real ni salir en ningún momento del entorno aislado que configuré para la práctica.

Referencias

- TrustedSec. (s. f.). Social-Engineer Toolkit (SET) [Repositorio de software]. GitHub. <https://github.com/trustedsec/social-engineer-toolkit>
- INCIBE. (s. f.). Phishing: conoce a fondo esta técnica de fraude. Oficina de Seguridad del Internauta. <https://www.incibe.es/aprendeciberseguridad/phishing>
- INCIBE. (s. f.). Cómo evitar ser víctima de phishing. <https://www.incibe.es/node/485661>
- Kali Linux Documentation. (s. f.). Social Engineering Toolkit (SET). <https://www.kali.org/tools/set/>